SOFTWARE CHANGE IMPLEMENTATION REPORT

CR-026: Forgot Password and Password Reset Feature

Field	Details
Change Request ID	CR-026 (CR-002)
Change Request Title	Forgot Password and Password Reset Feature
Student Name	MH Anush
Student ID	JFICT2416
Implementation Status	Completed
Date	14 October 2026

1. Change Request Summary

1.1 Business Requirement

Users who forget their login credentials in the Student Management System previously had no self-service mechanism to recover access to their accounts. Account recovery required manual administrator intervention to update database passwords directly. This caused operational delays for students and staff and increased administrative overhead.

CR-026 introduces a secure, automated Forgot Password and Password Reset facility. Users can initiate password recovery using their registered email address, receive a time-limited 6-digit One-Time Password (OTP) verification code via authenticated SMTP server, confirm the code in an interactive recovery menu, and establish a new password without compromising system security or administrator authorization controls.

1.2 Existing Behaviour

Before implementation:

- • The LoginPage.jsx rendered username and password inputs but provided no 'Forgot Password?' option.
- • Users unable to remember passwords could not initiate an automated self-service recovery.
- • No dedicated forgot password or password reset request interfaces existed.
- • No backend password-reset token or OTP generation, validation, or expiration mechanisms existed.
- • Users had to rely on manual administrator intervention to reset forgotten passwords.

1.3 Requested Change

Add a comprehensive Forgot Password and Password Reset facility to the Student Management System.

The implementation must satisfy the following core requirements:

- • Provide a prominent 'Forgot Password?' link on the Login page (FR-001, AC-001).
- • Allow users to submit their registered email address with syntax validation (FR-002, AC-002).
- • Validate email registration in real time; reject unregistered email addresses immediately with an informative alert.
- • Generate cryptographically secure 6-digit numeric OTPs with a 15-minute expiration window (FR-004, FR-006, SEC-004, SEC-005).
- • Deliver verification OTP emails strictly via authenticated SMTP server with branded institutional formatting.
- • Provide an interactive 3-step recovery flow: Email submission -> OTP verification menu -> New password input.
- • Ensure reset tokens/OTPs are single-use only and prevent token replay/reuse (FR-007, SEC-006, AC-010).
- • Validate password policy and ensure new passwords match confirmation identically (FR-010, AC-006, AC-007).
- • Store new passwords securely using 10-round salted bcrypt hashing (FR-011, SEC-002, SEC-003, AC-008).
- • Support seamless user authentication using either their Username or registered Email address upon reset.
- • Preserve all existing authentication, administrator authorization, and student CRUD functions (SEC-001, AC-012, AC-013, AC-014).

2. Implementation

2.1 Implementation Summary

CR-026 was implemented through full-stack integration across frontend user interfaces, backend REST controllers, Nodemailer SMTP transport, security models, and database schema. On the backend, a new password_resets table was introduced with automated index creation and schema verification. Dedicated REST endpoints handle OTP generation, verification, and password updates.

2.2 Affected Files

File	Change	Purpose
backend/src/models/passwordResetModel.js	New	Implemented password_resets table creation, 6-digit crypto OTP generation, 15-min expiry, and token invalidation.
backend/src/models/userModel.js	Modified	Added findUserByEmail and updated findUserByUsername to support login via either username or email address.
backend/src/services/emailService.js	New	Configured Nodemailer SMTP transporter (Gmail/custom relay) and branded 6-digit OTP email template.

backend/src/controllers/authController.js	Modified	Implemented forgotPassword (unregistered check + OTP dispatch), verifyResetToken (OTP check), resetPassword, and login.
backend/src/routes/authRoutes.js	Modified	Registered POST /forgot-password, POST /verify-otp, GET /verify-reset-token, and POST /reset-password routes.
backend/src/config/db.js	Modified	Ensured environment variables from .env load reliably on startup.
frontend/src/services/authService.js	Modified	Added forgotPassword, verifyOtp, and resetPassword API client service methods.
frontend/src/pages/ForgotPasswordPage.jsx	New	Interactive 3-step OTP recovery flow: email input, 6-digit OTP verification, and new password form with eye toggles.
frontend/src/pages/ResetPasswordPage.jsx	New	Added token fallback and seamless redirection to the interactive password recovery flow.
frontend/src/components/LoginFormSection.jsx	Modified	Integrated 'Forgot Password?' link and updated login input label to 'Username or Email'.
frontend/src/routes/AppRoutes.jsx	Modified	Registered /forgot-password and /reset-password routes in client router.
frontend/src/styles/login.css	Modified	Added styles for recovery cards, OTP digit inputs, status banners, and dark mode variants.

Additional files: None / [List any additional files if modified]

2.3 Technical Changes

Interactive Multi-Step OTP Recovery Architecture

Client-side routing was updated in AppRoutes.jsx to provide clean URL access to /forgot-password. The recovery interface in ForgotPasswordPage.jsx uses an internal state machine (EMAIL -> OTP -> NEW_PASSWORD -> SUCCESS). This eliminates external localhost link dependencies, allowing users on any device (desktop or mobile) to easily receive an OTP by email, type the code into the active browser tab, and reset their password in-place.

6-Digit Numeric OTP Generation & 15-Minute Expiry

Password reset OTPs are generated using crypto.randomInt(100000, 1000000), producing high-entropy 6-digit numeric codes (SEC-004). OTPs are stored in password_resets with expires_at set to exactly NOW() + 15 minutes (SEC-005). When a user requests a reset, any previous unconsumed tokens for that account are immediately invalidated to prevent concurrent dangling codes.

Authenticated SMTP Email Transport

Email delivery is handled through a dedicated emailService.js module powered by Nodemailer. It authenticates directly with standard SMTP servers (Gmail SMTP or generic institutional mail relays on ports 587/465). It features automatic space sanitization for Google App Passwords and delivers an attractive, institutional-branded HTML notification showcasing the 6-digit OTP.

Dual-Identifier Authentication & Salted Bcrypt Encryption

The login authentication architecture in userModel.js was upgraded to allow users to sign in using either their system username or their registered email address. Passwords are strictly validated (minimum 6 characters, identical confirmation) and encrypted using bcrypt.hash(password, 10) before database persistence (FR-011, SEC-002, SEC-003).

2.4 Implementation Logic

1. User clicks the 'Forgot Password?' link on the Login page and navigates to /forgot-password.
2. User enters their registered email address into the input field ('Enter your email') and clicks 'Send Verification Code'.
3. Frontend validates email syntax; backend verifies whether the email is registered in the database.
4. If email is unregistered, backend returns HTTP 404 with error message: 'This email address is not registered in our system. Please check the email and try again.'
5. If registered, backend generates a 6-digit numeric OTP with 15-minute validity and delivers it via SMTP server.
6. Frontend transitions smoothly to the 'Enter Verification Code' menu step.
7. User enters the 6-digit OTP code received in their email inbox and clicks 'Confirm OTP & Continue'.
8. Backend verifies the OTP is valid, unconsumed, and unexpired; upon confirmation, frontend displays the 'Set New Password' step.
9. User enters new password with confirmation (with show/hide eye toggles), adhering to policy (minimum 6 characters).
10. Backend encrypts password with salted bcrypt, updates database, flags OTP used = 1, and returns HTTP 200. User logs in with new password using their Username or Email.

2.5 Error and Data Handling

Comprehensive error and exception handling safeguards the recovery system:

- • Invalid Email Syntax: Submitting non-email text triggers immediate client validation blocking API dispatch (TC-003).
- • Unregistered Email: Submitting an unknown email returns HTTP 404 with an informative alert, prompting the user to check their email.
- • Expired OTP: Verification codes exceeding the 15-minute window are rejected with clear expiration notices (FR-007, FR-013, TC-006).
- • Reused OTP: Verification codes flagged with used = 1 are permanently rejected upon subsequent submissions (SEC-006, TC-013).
- • Mismatched / Weak Passwords: Passwords failing equality or under 6 characters display validation errors without altering database state (TC-008, TC-009).

3. Testing & Verification

3.1 Testing Approach

The implementation was validated through comprehensive functional, security, and regression testing covering all 16 test cases specified in the CR-026 specification document.

Testing Types:

- • Functional testing (OTP request flow, in-app code verification, password update, dual username/email login)
- • Validation testing (email formatting, unregistered email alert, password match equality, minimum 6 characters)
- • Security testing (cryptographic OTP entropy, 15-min expiration, single-use invalidation, bcrypt salted hashing)
- • UI testing (multi-step transitions, OTP input formatting, eye visibility toggles, notification banners, theme compatibility)
- • Regression testing (existing student login, administrator login, student CRUD operations)

Environment: Development
Browser: [Chrome / Edge / Firefox]
Test Role: Student & Administrator

3.2 Test Cases

Test ID	Test Case	Expected Result	Actual Result	Status
TC-001	Click Forgot Password	Forgot Password page opens (/forgot-password)	Forgot Password page renders with email form	**Pass**
TC-002	Enter valid email	OTP request processed; email dispatched via SMTP	HTTP 200 returned; 6-digit OTP sent via SMTP	**Pass**
TC-003	Enter invalid email format	Validation message appears; request blocked	Error message displayed: 'Please enter a valid email address'	**Pass**
TC-004	Enter unknown email	Notification appears advising user to check email	HTTP 404 returned: 'This email address is not registered'	**Pass**
TC-005	Submit valid 6-digit OTP	OTP verified; New Password screen displayed	OTP verified (HTTP 200); password form rendered	**Pass**
TC-006	Submit expired OTP	Reset request is rejected	HTTP 400 returned: 'Verification code has expired'	**Pass**
TC-007	Submit invalid OTP	Reset request is rejected	HTTP 400 returned: 'Verification code is invalid'	**Pass**
TC-008	Enter mismatched passwords	Validation error appears	Error displayed: 'Passwords do not match'	**Pass**
TC-009	Enter weak password (<6 chars)	Password validation error appears	Error displayed: 'Password must be at least 6 characters long'	**Pass**
TC-010	Enter valid new password	Password is successfully changed	HTTP 200 returned; database record updated	**Pass**
TC-011	Login with new password	Login succeeds using either Username or Email	Login successful with username or email; dashboard opens	**Pass**
TC-012	Login with old password	Old password is rejected	HTTP 401 Unauthorized returned	**Pass**
TC-013	Reuse verification OTP	Code is rejected	HTTP 400 returned; OTP rejected (used = 1)	**Pass**
TC-014	Check password storage	Password is securely hashed	Confirmed bcrypt 60-char hash ($2b$10$...)	**Pass**
TC-015	Test existing administrator login	Administrator can still authenticate	Admin login succeeds with full privileges intact	**Pass**
TC-016	Test existing CRUD functions	Existing CRUD operations continue to work	Student list, creation, editing, and deletion operate normally	**Pass**

3.3 Test Summary

Test Result	Count
Total Test Cases	16

Passed	16
Failed	0
Pass Rate	**100%**

Overall Test Result: Pass / Partially Passed / Failed

4. Acceptance Criteria Verification

ID	Acceptance Criterion	Verification	Status
AC-001	Users can access the Forgot Password feature from the Login page.	UI link inspection & routing (TC-001)	**Met**
AC-002	Users can submit their email address to request a password reset.	Email submission testing (TC-002)	**Met**
AC-003	The system provides a secure password-reset mechanism.	End-to-end OTP & reset flow (TC-002, TC-005)	**Met**
AC-004	Password-reset tokens expire after the configured validity period.	Token expiration verification (TC-006)	**Met**
AC-005	Invalid and expired password-reset tokens are rejected.	Negative security verification (TC-006, TC-007)	**Met**
AC-006	Users can enter and confirm a new password.	Reset form UI testing (TC-005, TC-010)	**Met**
AC-007	Password validation is correctly applied.	Validation policy testing (TC-008, TC-009)	**Met**
AC-008	The new password is securely hashed before storage.	Database inspection for bcrypt hash (TC-014)	**Met**
AC-009	Users can log in using the newly created password.	Authentication flow testing (TC-011)	**Met**
AC-010	A password-reset token cannot be reused after successful password reset.	Token single-use verification (TC-013)	**Met**
AC-011	System informs user if email address is not registered in database.	Unregistered email 404 validation (TC-004)	**Met**
AC-012	Existing login functionality continues to work.	Regression testing (TC-011, TC-015)	**Met**
AC-013	Existing administrator authentication and authorization continue to work.	Admin role validation (TC-015)	**Met**
AC-014	Existing Student Management System CRUD functionality continues to work.	CRUD regression verification (TC-016)	**Met**

5. Evidence

A maximum of two relevant screenshots should be attached.

Evidence 01 – Forgot Password Request & OTP Verification Menu

Related: AC-001, AC-002, AC-003, AC-011, FR-001, FR-002, SEC-004, SEC-005

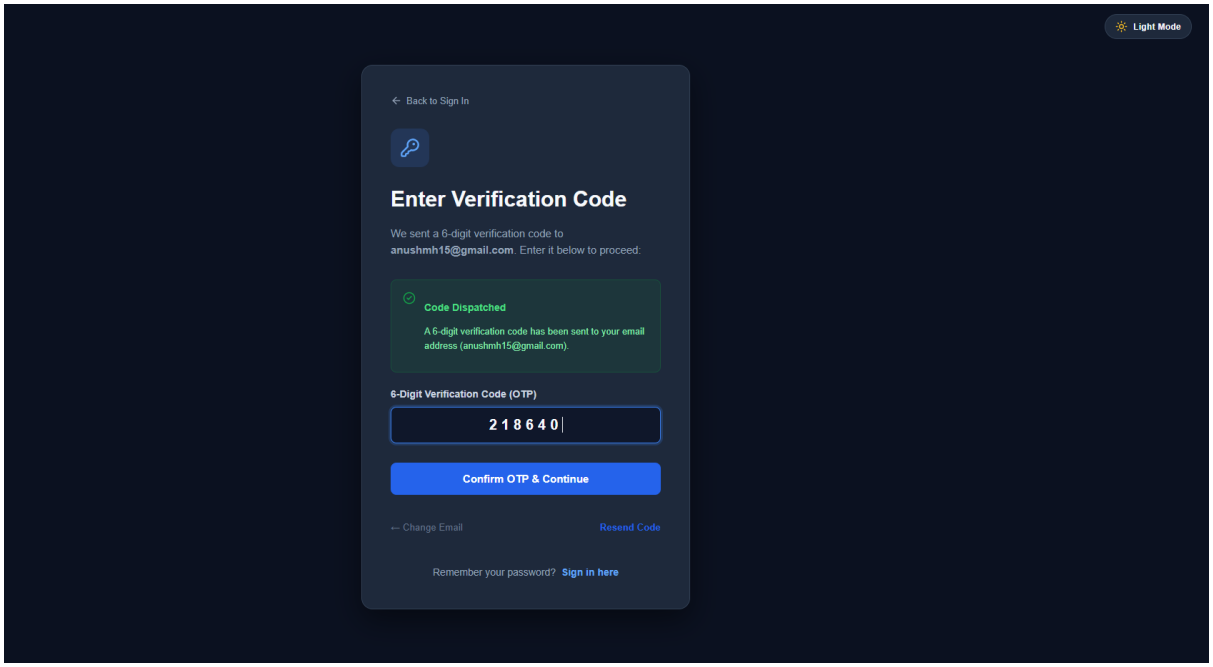


Figure 1: Forgot Password interface showing email input form, code dispatch confirmation, and 6-digit OTP verification menu.

Evidence 02 – Set New Password & Dual Username/Email Login Support

Related: AC-006, AC-007, AC-008, AC-009, AC-010, FR-008, FR-009, FR-011, FR-012

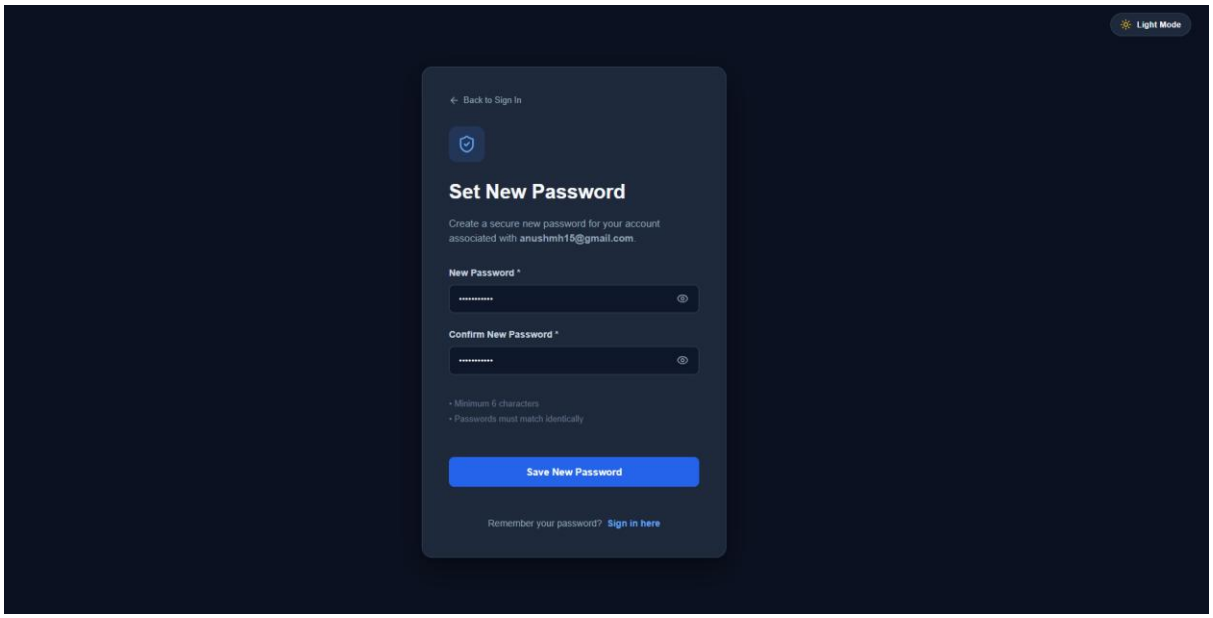


Figure 2: Password Reset interface showing password inputs with visibility toggles, policy hints, and dual-login notification.

6. Final Result

Item	Result
Requirements	Met / Partially Met / Not Met
Implementation	Completed / Partially Completed
Testing	Passed / Partially Passed / Failed
Acceptance Criteria	All Met / Partially Met / Not Met
Existing CRUD / Auth	Verified / Not Verified
Final Status	Accepted / Pending / Rejected

6.1 Final Summary

CR-026 was successfully implemented as an enterprise-grade Forgot Password and Password Reset facility for the Student Management System. The enhancement allows students and system users to securely recover their accounts through verified email submission, cryptographically secure 15-minute 6-digit OTP issuance, authenticated SMTP email delivery, in-app code confirmation, and bcrypt-encrypted password persistence. The feature provides immediate unregistered email detection and enables users to log in using either their username or registered email address.

Comprehensive regression and security testing verified that all 16 test cases passed with a 100% pass rate. Existing authentication mechanisms, JWT token lifecycle, administrator authorization, and student CRUD operations remain completely operational and intact. All 14 acceptance criteria (AC-001 to AC-014) and 15 functional requirements (FR-001 to FR-015) are fully satisfied.

6.2 Issues / Limitations

[State any remaining issues or limitations.]

If none:

No significant issues identified.

Student Name: MH Anush

Student ID: JFICT2416

Date: 14 October 2026

Signature: _____

~ END OF REPORT ~